

Работа 4 Анализ уязвимостей веб-приложения с помощью OWASP ZAP

Назначение: освоить базовые навыки динамического тестирования безопасности (DAST) на примере тестового приложения.

Задание

1. Установите OWASP ZAP (бесплатный инструмент).
2. Запустите встроенный браузер ZAP и перейдите на тестовый сайт (например, <http://testphp.vulnweb.com/>).
3. Проведите "Быстрое сканирование" (Quick Scan) сайта.
4. Проанализируйте результаты сканирования: найдите 3-5 различных типов уязвимостей (например, XSS, SQLi).
5. Сделайте скриншоты найденных уязвимостей и кратко опишите суть каждой.

Что сдают студенты

Краткий отчет в (2-3 стр.) со скриншотами и описанием уязвимостей.

Критерии оценки (макс. 10 баллов)

- **3 балла:** Корректное выполнение сканирования.
- **5 баллов:** Найдено и корректно классифицировано не менее 3 уязвимостей.
- **2 балла:** Качество оформления отчета (четкость, структурированность, наличие скриншотов).

Источники для теории

- Официальная документация OWASP ZAP: <https://www.zaproxy.org/docs/>
- OWASP Top 10: Краткое описание уязвимостей: <https://owasp.org/www-project-top-ten/>
- <https://owasp.org/www-chapter-dorset/assets/presentations/2020-01/20200120-OWASPDorset-ZAP-DanielW.pdf>

Контрольные вопросы

1. Чем динамическое тестирование (DAST) отличается от статического (SAST)?
2. Какие последствия может иметь уязвимость Cross-Site Scripting (XSS) для пользователя сайта?
3. Почему для тестирования нельзя использовать реальные коммерческие сайты?